

MARCO INTEGRATIVO GQM + PRAGMATIC

Para Indicadores de Ciberseguridad basados en CIS Controls v8.1 en España

Versión: 1.0

Fecha: Enero 2026

Contexto: Indicadores de ciberseguridad alineados con CIS Controls v8.1, NIST CSF 2.0, NIS2 Directive y realidad nacional española

EXECUTIVE SUMMARY

Este documento establece un **marco integrativo de dos metodologías complementarias**:

1. GQM (Goal-Question-Metric): Aseguran trazabilidad desde objetivos estratégicos (nacionales/organizacionales) hacia métricas técnicas operacionales
2. PRAGMATIC (9 Criterios): Garantizan que cada métrica sea práctica, viable, y orientada a la acción en contextos reales

Propósito: Diseñar un sistema de indicadores de ciberseguridad que:

-  Sea directamente accionable por equipos de seguridad
-  Comunique valor de negocio a ejecutivos/board
-  Se alinee con regulaciones españolas/europeas (NIS2, GDPR)
-  Sea medible en contexto real (no en laboratorio)
-  Permita trazabilidad desde objetivo nacional hasta dato técnico

1. METODOLOGÍA GQM: ESTRUCTURA CONCEPTUAL

1.1 ¿Qué es GQM?

Goal-Question-Metric es un framework sistemático de tres niveles:

NIVEL 1: GOAL (Objetivo Estratégico)

Qué queremos LOGRAR (por qué importa)
Ejemplo: "Detectar incidentes de ciberseguridad
dentro de 4 horas de ocurrencia"



NIVEL 2: QUESTION (Pregunta Operacional)

Cómo MEDIMOS progreso hacia ese objetivo
Ejemplo: "¿Cuál es el tiempo promedio desde que un
incidente ocurre hasta que lo detectamos?"



NIVEL 3: METRIC (Métrica Técnica)

Qué DATO ESPECÍFICO recogemos y cómo lo calculamos
Ejemplo: "MTTD (Mean Time To Detect) = promedio
(timestamp_detección - timestamp_evento)
para todos incidentes en período T"

1.2 Principios GQM Aplicados a Ciberseguridad

Principio 1: Trazabilidad Ascendente (Bottom-Up)

Cada métrica debe poder rastrearse hacia arriba:

MÉTRICA técnica



responde QUESTION operacional



da evidencia de logro de GOAL estratégico

Ejemplo Real España - Detectabilidad de Incidentes:

GOAL (Estratégico - CCN/INCIBE):

"Reduce tiempo de detección de incidentes en infraestructuras críticas al 50% en 12 meses (MTTD: 24h → 12h)"

¿POR QUÉ? Ventana de oportunidad para atacantes. Cada hora es riesgo exponencial. NIS2 requiere reporte en 24h; detectar en <12h permite margen.

└ QUESTION (Nivel Táctico - CISO/SOC Director):

"¿Estamos mejorando en velocidad de detección?"

Sub-questions:

- ¿Cuál es MTTD promedio actual?
- ¿Qué eventos están siendo detectados vs no detectados?
- ¿Dónde están los gaps de detección?
- ¿SIEM, EDR, IDS/IPS están correlacionando?

└ METRIC (Nivel Operacional - SOC Analyst, SIEM Admin):

M1.1: MTTD (Mean Time To Detect)

Fórmula: $\text{Promedio}(\text{timestamp_alert} - \text{timestamp_evento})$

Fuente: SIEM logs, timestamps de eventos

Frecuencia: Diario

Unidad: Horas

Target: <12h para críticos, <24h para altos

M1.2: % Eventos Detectados

Fórmula: $(\text{Eventos detectados} / \text{Eventos totales simulados}) \times 100$

Fuente: BAS (Breach & Attack Simulation) + Actual incidents

Frecuencia: Semanal/Mensual

Unidad: Porcentaje (%)

Target: >95% para eventos críticos

M1.3: Brecha de Detección por Técnica ATT&CK

Fórmula: $\text{Técnicas no detectadas} / \text{Técnicas totales en threat model}$

Fuente: MITRE ATT&CK mapping + Red Team Results

Frecuencia: Trimestral

Unidad: Porcentaje (%)

Target: <5% gap (ej: 233 de 241 técnicas detectables)

Principio 2: Objetividad (Reflejable, No Subjetivo)

Cada métrica GQM debe ser **medible objetivamente**, no interpretable:

✗ **SUBJETIVO** (No es GQM válida):
"¿Qué tan buenos somos en detección?"
Respuesta: "Bastante buenos"
→ No medible, no repetible

✓ **OBJETIVO** (GQM válida):
"MTTD promedio últimas 30 días = 8.5 horas"
→ Medible, repetible, comparable

2. CRITERIOS PRAGMATIC: VALIDACIÓN DE VIABILIDAD

2.1 Los Nueve Criterios PRAGMATIC

Una métrica GQM bien definida aún requiere validación contra criterios de viabilidad real:

Criterio	Definición	Preguntas Críticas	Aplicación Ciberseguridad
P: Predictivo	¿Predice o anticipa problemas futuros?	"¿Veremos tendencias antes de que ocurran?"	MTTD en descenso → indicador de mejora proactiva futura
R: Relevante	¿Es importante para stakeholders?	"¿A quién le importa este dato?"	Relevante a CISO, board, NIS2 compliance
A: Accionable	¿Permite tomar decisiones reales?	"¿Qué cambiaremos si métrica sube/baja?"	Si MTTD sube, escalar recursos SOC
G: Genuino	¿Es verdadera medida de lo que pretende?	"¿Realmente mide lo que queremos?"	MTTD genuinamente mide velocidad detección
S: Significativo	¿Tiene impacto comercial/de riesgo notable?	"¿Importa para negocio?"	MTTD → riesgo financiero → ROI de SIEM
P: Preciso	¿Sin ambigüedad en cálculo?	"¿Todos calculan igual?"	Fórmula explícita; timestamp exacto
T: Oportuno	¿Disponible cuando se necesita?	"¿Tenemos dato hoy, no en 3 meses?"	SIEM disponible diariamente (no anual)
I: Independiente	¿No distorsionada por factores externos?	"¿Cambios reflejan esfuerzo nuestro, no externos?"	MTTD = esfuerzo SOC + tecnología; no weather
C: Rentable	¿Costo de recogida < valor obtenido?	"¿Gastamos €10k para saber €5k info?"	SIEM ya existe; costo = tiempo análisis (bajo)

2.2 Matriz PRAGMATIC de Evaluación

Para cada métrica, evaluaremos cada criterio con escala 0-3:

0 = No cumple criterio (NO implementar)
1 = Cumple parcialmente (Riesgoso; considerar alternativa)
2 = Cumple ampliamente (Aceptable)
3 = Cumple completamente (Óptimo)

Score PRAGMATIC Total = Promedio(9 criterios)

Benchmark:

- Score ≥ 2.5 : Métrica RECOMENDADA
- Score 1.5-2.4: Métrica CONDICIONAL (requiere ajustes)
- Score < 1.5 : Métrica NO RECOMENDADA

3. MARCO INTEGRADOR GQM + PRAGMATIC

3.1 Proceso de Diseño de Indicadores

PASO 1: DEFINIR GOAL ESTRATÉGICO (Nivel Nacional/Organizacional)

- Consultar objetivos CCN/INCIBE (nivel nacional)
- 0 definir objetivo organizacional alineado con NIS2/NIST
- Formato: "[Verbos de mejora] [aspecto de seguridad]
en [plazo] de [métrica baseline] a [métrica target]"

Ejemplo: "Reducir MTTD de 24h a <4h en 12 meses"



PASO 2: DESCOMPONER EN QUESTIONS (Nivel Táctico)

- ¿Qué operacionalmente necesito saber para saber si GOAL se logra?
- Típicamente 3-5 questions por goal
- Formato: "¿[ASPECTO MEDIBLE]?"

Ejemplo Questions para MTTD:

Q1: ¿Cuál es MTTD promedio actual?

Q2: ¿Qué eventos NO son detectados?

Q3: ¿Cuál es distribución de MTTD (min/max/mediana)?



PASO 3: DERIVAR METRICS ESPECÍFICAS (Nivel Operacional)

- ¿Qué dato específico responde cada question?
- Típicamente 1-3 metrics por question
- Formato: [NOMBRE].
Fórmula: [CÁLCULO EXACTO]
Fuente: [DONDE VIENE DATO]
Frecuencia: [CADA CUÁNDO]

Ejemplo Metrics:

M1: MTTD (Mean Time To Detect) = $\text{Avg}(t_{\text{detect}} - t_{\text{event}})$

M2: $\text{Detection_Gap_Rate} = (\text{Eventos no detectados} / \text{Total}) \times 100$

M3: MTTD_Percentile_p99 = Percentil 99 de MTTD distribution



PASO 4: EVALUAR PRAGMATIC (Validación de Viabilidad)

- Para CADA métrica, puntuarla en 9 criterios PRAGMATIC
- Si Score ≥ 2.5 → IMPLEMENTAR
- Si Score < 1.5 → RECHAZAR o REDISEÑAR
- Si 1.5-2.4 → CONDICIONAL (requiere mitigación)

Ejemplo:

M1 MTTD: P=3, R=3, A=3, G=3, S=3, P=3, T=3, I=2, C=3

Score = 2.87  IMPLEMENTAR



PASO 5: DEFINIR OPERACIONALMENTE (Especificación Completa)

- Propietario de métrica
- Frecuencia de reporte
- Target/Benchmark
- Cómo se visualiza

- Escalaciones (qué hacer si métrica sale de rango)
- Data governance (quién tiene acceso)

Resultado: Metric Card (ver sección 4.2)

4. EJEMPLOS CONCRETOS ESPAÑA: CIS CONTROLS + QM + PRAGMATIC

4.1 Ejemplo 1: Detectabilidad de Incidentes (MTTD)

Alineación:

- CIS Control: 4.4 (SIEM - Detect function)
- NIST CSF 2.0: DETECT (DE.DP-4 Event Analysis)
- NIS2 Art. 20: Capacidad de detectar anomalías de seguridad

GQM + PRAGMATIC CARD
"MEAN TIME TO DETECT (MTTD)"

1. GOAL (Estratégico)

Objetivo: Detectar incidentes de ciberseguridad dentro de 4 horas de ocurrencia para minimizar daño y cumplir NIS2
Contexto: España 2024 promedio MTTD = 24h; meta 2026 = 4h
Impacto: Cada hora de no-detección = exponencial riesgo financiero
Benchmark Sector Financiero = 2-4h (líderes)

2. QUESTIONS (Tácticas)

Q1: ¿Cuál es MTTD promedio en evento de incidente?
Q2: ¿Hay variación significativa por tipo evento (malware vs intrusion)?
Q3: ¿Qué eventos NO están siendo detectados en tiempo real?

3. METRICS (Operacionales)

M3.1: Mean Time To Detect (MTTD)

Fórmula: $MTTD = AVG(timestamp_SIEM_alert - timestamp_evento_real)$
Para todos eventos con Alert Status = "Triggered"
Período: Últimos 30 días

Fuente: SIEM logs (Splunk/Sentinel)
+ Timestamp de evento en timestamp_created
+ Timestamp de detección/alert en timestamp_triggered

Cálculo: (Timestamp_generated - Timestamp_occurred) para cada evento
Excluir outliers $>3\sigma$ (falsos positivos)
Promediación temporal simple

Frecuencia: Diaria (actualización automática)
Reporte: Semanal + Mensual

Unidad: Horas (decimales aceptados)
Target: <4 horas promedio
P99: <24 horas (máximo 99th percentile)

M3.2: Detection Coverage by ATT&CK Technique

Fórmula: $\% \text{ Techniques Detected} = (\text{Técnicas Detectadas} / \text{Técnicas Totales en Threat Model}) \times 100$

Fuente: BAS (Breach & Attack Simulation quarterly)
+ Red Team exercises (biannual)
+ MITRE ATT&CK mapping

Frecuencia: Trimestral (BAS)
Biannual (Red Team)

Target: >95% de técnicas críticas
>80% de técnicas medias

M3.3: Events Not Detected (Detection Gaps)

Fórmula: $Gap_Rate = (\text{Eventos en logs sin SIEM alert}) / \text{Total eventos}$

Fuente: Comparación: Network TAP / Sysmon logs vs SIEM
(Detective control: passive network monitoring)

Frecuencia: Semanal

Target: <0.5% de eventos críticos
<2% de eventos no-críticos

4. EVALUACIÓN PRAGMATIC (Escala 0-3)

Criterio	Score	Justificación
P - Predictivo	3	Tendencia MTTD ↓ = mejora proactiva; Tendencia ↑ = alerta
R - Relevante	3	Crítico para CISO, board, NIS2
A - Accionable	3	Si MTTD ↑ → escalar SOC, mejorar SIEM rules, EDR
G - Genuino	3	Verdadera medida de velocidad
S - Significativo	3	Riesgo financiero directo
P - Preciso	3	Fórmula exacta, sin ambigüedad
T - Oportuno	3	SIEM data available daily
I - Independiente	2	MTTD depende de tooling + personal (ambos controlables)
C - Rentable	3	SIEM ya existe; costo marginal
SCORE PRAGMATIC TOTAL:	2.89	✓ IMPLEMENTAR

5. OPERACIONALIZACIÓN

Propietario: Director SOC / Security Operations Lead
Reporta a: CISO Monthly / Board Quarterly
Frecuencia: Daily (automated), Weekly/Monthly aggregation

Visualización: Dashboard SIEM con línea de tendencia
• Gráfico tiempo: MTTD últimos 90 días
• Box plot: Distribución (min/q1/median/q3/max)
• Heatmap: MTTD por tipo evento

Escalaciones:

- Si MTTD > 8h → Alert (amarillo) + revisar SIEM rules
- Si MTTD > 24h → Critical (rojo) + reunión de crisis SOC
- Si Detection_Gap > 2% → Yellow + investigación de bypass

Benchmarking:

- Comparar mensualmente vs target <4h
- Comparar trimestralmente vs sector financiero (2-4h)
- Comparar vs anteriores trimestres (tendencia)

Data Governance:

- Acceso: CISO, SOC Manager, Compliance Officer
- Confidencialidad: Internal - Confidential
- Retención: 3 años histórico
- Auditoría: Cambios loguados en SIEM

4.2 Ejemplo 2: Gestión de Vulnerabilidades (Remediation Velocity)

Alineación:

- CIS Control: 4.1 (Vulnerability Management - PROTECT)
- NIST CSF 2.0: PROTECT (PR.PS-6 Vulnerability Management)
- NIS2 Art. 20: Evaluación de vulnerabilidades

GQM + PRAGMATIC CARD
"VULNERABILITY REMEDIATION VELOCITY (MTTV)"

1. GOAL (Estratégico)

Objetivo: Remediar vulnerabilidades críticas dentro de 7 días
para minimizar ventana de explotación
Contexto: España 2024 promedio MTTV críticas = 60 días
Meta 2026 = 7 días (alineado CISA, NSA guidance)
Impacto: Vulnerabilidades sin parchear = 40% de breaches

2. QUESTIONS (Tácticas)

Q1: ¿Cuánto tarda promedio remediar vulnerabilidades críticas?
Q2: ¿Cuál es distribución de MTTV (hay colas largas)?
Q3: ¿Dónde están gaps en proceso remediación?

3. METRICS (Operacionales)

M4.1: Mean Time To Remediate (MTTV) por Severidad

Fórmula: $MTTV_{crítica} = AVG(timestamp_remediated - timestamp_discovered)$
Para vulnerabilidades CVSS ≥ 9.0

Fuente: Vulnerability scanner (Nessus/Qualys)
+ Patch management system
+ Ticketing system (ServiceNow/Jira)

Frecuencia: Semanal / Mensual

Target: Critical CVSS 9-10: <7 días
High CVSS 7-8.9: <30 días
Medium CVSS 4-6.9: <90 días

P95: Máximo 2x del promedio

M4.2: Vulnerability Backlog Aging

Fórmula: $\% \text{ Vulnerabilidades } > SLA = (Vulns \text{ sin remediar } > SLA / \text{ Total open}) \times 100$

Fuente: Vulnerability database

Frecuencia: Semanal

Target: <5% vulnerabilidades críticas sin remediar >7d
<15% vulnerabilidades altas sin remediar >30d

M4.3: Patching Success Rate

Fórmula: $\% \text{ Successfully Patched} = (\text{Assets patched} / \text{Assets targeted}) \times 100$

Frecuencia: Post-patch window

Target: >95% first attempt success

4. EVALUACIÓN PRAGMATIC

Criterio	Score	Justificación
P - Predictivo	3	Backlog ↑ = futuro breach riesgo
R - Relevante	3	Crítico para CISO, IT director
A - Accionable	3	Si MTTV ↑ → escalar patching

G - Genuino	3	Verdadera medida remediación
S - Significativo	3	Directo a breach probability
P - Preciso	3	Fórmula timestamp clara
T - Oportuno	2	Scan frecuencia: limitación (semanal, no diaria)
I - Independiente	2	Depende de disponibilidad mantenimiento (limitado)
C - Rentable	2	Scanner costo 10-50k/año
SCORE PRAGMATIC TOTAL:		2.67 ☒ IMPLEMENTAR

5. ALINEACIÓN NACIONAL: INDICADORES PRIORITARIOS ESPAÑA

5.1 Objetivos Nacionales (CCN/INCIBE) → GQM

Objetivos Nacionales 2024-2026:

(Basados en Plan Nacional Ciberseguridad + NIS2 transposición)

Objetivo Nacional	Plazo	GQM GOAL	Métricas Asociadas
Reducir MTTD en infraestructura crítica	12 meses	Detectar 95% incidentes en <12h	M3.1, M3.2, M3.3
Mejorar capacidad remediación vulnerabilidades	18 meses	Remediar 95% críticas en <7d	M4.1, M4.2, M4.3
Aumentar cobertura de autenticación multifactor	12 meses	100% acceso crítico con MFA	M5.x
Implementar SCRM formal	6 meses (NIS2)	100% proveedores críticos evaluados	M8.x
Mejorar conciencia de seguridad	Continuo	Reducir phishing click rate <5%	M5.x

6. VALIDACIÓN DEL MARCO

6.1 Checklist de Validez GQM

Para asegurar cada Goal—Question—Metric es válida:

- ☐ **GOAL**
 - ☐ Contiene verbo de mejora (reducir, aumentar, detectar)
 - ☐ Especifica plazo (12 meses, Q2 2026)
 - ☐ Contiene métrica baseline y target
 - ☐ Alineado a objetivo nacional o regulatorio
- ☐ **QUESTION**
 - ☐ Es pregunta abierta (no sí/no)
 - ☐ Responde directamente al GOAL
 - ☐ Es operacionalmente relevante
 - ☐ 3-5 questions por goal
- ☐ **METRIC**
 - ☐ Fórmula exacta (sin ambigüedad)
 - ☐ Fuente de datos especificada
 - ☐ Frecuencia clara
 - ☐ Unidad definida
 - ☐ Target y benchmark especificados
 - ☐ Score PRAGMATIC ≥ 2.5

CONCLUSIONES

El Marco GQM + PRAGMATIC proporciona:

3. Trazabilidad clara: Desde objetivo nacional → GOAL → QUESTION → METRIC
4. Viabilidad garantizada: Cada métrica validada contra 9 criterios PRAGMATIC
5. Accionabilidad: Métricas orientadas a decisiones reales (no vanity metrics)
6. Comparabilidad: Métricas estandarizadas permiten benchmarking sectorial
7. Sostenibilidad: Framework iterable; permite evolución continua

Documento Versión 1.0 | Enero 2026 | España